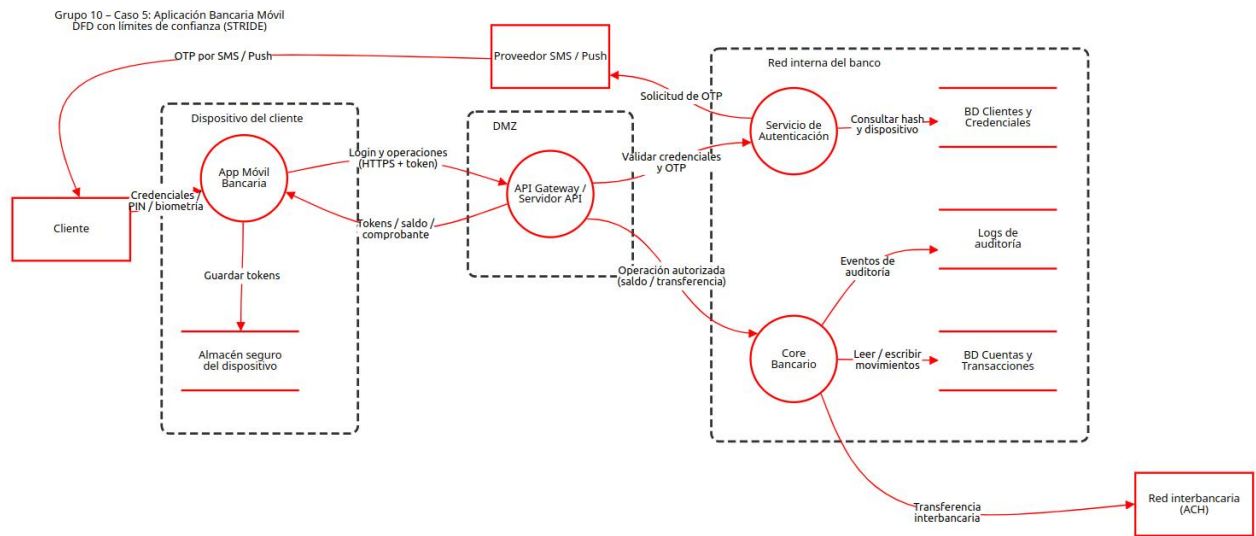


Reporte de modelo de amenaza para Grupo 10 – Caso 5: Aplicación Bancaria Móvil		
Propietario: Grupo 10 – Seguridad en DevOps (DevSecOps), UAGRM	Revisor: MSc. José Pablo Villazón Valdez	Colaboradores: Bautista Condori Anderzon, Grichukin Méndez Richard, Rada Rojas Andrés Fidel, Vargas Ríos Bebi

Resumen Ejecutivo	
Descripción de alto nivel del sistema (high level system) Modelo de amenazas STRIDE de una aplicación bancaria móvil: login, consulta de saldo y transferencias. Flujo: Cliente (App) → Servidor API → Core Bancario → Base de Datos.	
Resumen	
Metric	Total
Total amenazas	41
Total amenazas mitigadas	0
No Mitigadas	41
Abierto / Crítica Prioridad	0
Abierto / Alta Prioridad	19
Abierto / Prioridad Media	17
Abierto / Baja Prioridad	5

DFD – Aplicación Bancaria Móvil

Diagrama de flujo de datos con límites de confianza: dispositivo, DMZ y red interna.



Cliente (Actor)

Descripción: Titular de la cuenta que usa la app desde su teléfono.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
	T01 – Robo de credenciales por phishing o app falsa	Spoofing	Alta	Abierto		Un atacante envía un SMS/correo con un enlace a una app o sitio clonado y obtiene usuario, PIN y OTP del cliente.	Autenticación resistente a phishing (FIDO2/passkeys o clave ligada al dispositivo); App Links verificados; monitoreo de apps clonadas en tiendas; campañas de concientización. Referencia: NIST SP 800-63B; MASVS-AUTH
	T02 – Toma de cuenta por SIM swapping	Spoofing	Alta	Abierto		El atacante duplica el chip del cliente en la operadora y recibe los OTP por SMS para activar la app en otro dispositivo.	Vinculación de dispositivo con clave criptográfica; consulta de cambio reciente de SIM a la operadora; periodo de espera y notificación al activar un nuevo dispositivo. Referencia: NIST SP 800-63B §5.1.3.3
	T03 – Cliente niega haber ordenado una transferencia	Repudiation	Media	Abierto		Sin evidencia sólida, el cliente puede disputar una transferencia legítima (o una fraudulenta no puede demostrarse).	Firma de cada transacción con la clave privada del dispositivo tras biometría local; registro de la evidencia (dispositivo, IP, hora, firma) en logs inmutables. Referencia: PSD2 RTS (SCA, dynamic linking)

Proveedor SMS / Push (Actor)

Descripción: Servicio externo que entrega el código OTP o la notificación push al cliente.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
	T20 – Suplantación del proveedor de SMS / Push	Spoofing	Baja	Abierto		Webhooks de confirmación falsos o credenciales robadas del proveedor permiten enviar mensajes fraudulentos.	Autenticación mutua (mTLS / API keys rotadas) y verificación de firma en webhooks; mínimo privilegio en la cuenta del proveedor. Referencia: OWASP ASVS V13

Red interbancaria (ACH) (Actor)

Descripción: Cámara de compensación que procesa transferencias hacia otros bancos.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
	T34 – Red interbancaria niega haber recibido una orden	Repudiation	Media	Abierto		Ante una transferencia interbancaria fallida o disputada, la cámara o el banco destino niega haber recibido la orden y no hay prueba de envío.	Acuses de recibo firmados por la cámara; registro del mensaje enviado y del acuse en logs inmutables; conciliación diaria con la red interbancaria. Referencia: ISO 20022; PCI DSS 10

App Móvil Bancaria (Proceso)

Descripción: Aplicación Android/iOS: login, consulta de saldo y transferencias.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
	T04 – App modificada o instrumentada (Frida, reempaquetado)	Tampering	Alta	Abierto		En un teléfono con root/jailbreak el atacante modifica la app para saltar controles o capturar datos.	Detección de root/jailbreak y hooking (RASP); atestación con Play Integrity / App Attest verificada en el servidor; ofuscación de código. Referencia: MASVS-RESILIENCE
	T05 – Datos sensibles en capturas, caché o logs del teléfono	Information disclosure	Media	Abierto		Saldos, números de cuenta o tokens quedan en capturas de pantalla, portapapeles, caché o logcat.	FLAG_SECURE / ocultar vista en segundo plano; no registrar datos sensibles; limpiar caché al cerrar sesión; deshabilitar copiado de campos sensibles. Referencia: MASVS-STORAGE; MASVS-PLATFORM
	T06 – Controles de autorización implementados solo en la app	Elevation of privilege	Alta	Abierto		Límites de monto o funciones ocultas en la interfaz se evitan llamando directamente a la API.	Toda regla de negocio y autorización se valida en el servidor; la app solo presenta la información. Referencia: OWASP API Security Top 10 (API5)

API Gateway / Servidor API (Proceso)

Descripción: Punto de entrada público: TLS, autenticación de tokens, rate limiting, enrutamiento.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
	T12 – Tokens JWT falsificados o manipulados	Spoofing	Alta	Abierto		El atacante altera un JWT (alg=none, clave débil, cambio de 'sub') para hacerse pasar por otro cliente.	Validar firma con algoritmos permitidos (RS256/ES256), 'iss', 'aud' y 'exp'; rotación de claves (JWKS); tokens de vida corta. Referencia: RFC 8725 (JWT BCP)
	T13 – Fuerza bruta, credential stuffing y DDoS	Denial of service	Alta	Abierto		Bots prueban miles de combinaciones de usuario/PIN o saturan la API para dejar sin servicio a los clientes.	Rate limiting por IP, usuario y dispositivo; bloqueo progresivo; WAF y protección anti-DDoS; atestación de la app para distinguir bots. Referencia: OWASP API Security Top 10 (API4)
	T14 – Acceso a cuentas de otros clientes (BOLA/IDOR)	Elevation of privilege	Alta	Abierto		Cambiando el número de cuenta en la solicitud, un cliente autenticado consulta saldos o mueve fondos de otra cuenta.	Autorización a nivel de objeto en cada endpoint: la cuenta debe pertenecer al 'sub' del token; pruebas automáticas de autorización. Referencia: OWASP API Security Top 10 (API1)
	T15 – Mensajes de error detallados	Information disclosure	Media	Abierto		Trazas de pila o mensajes de error revelan versiones, consultas SQL o estructura interna.	Mensajes genéricos al cliente con un identificador de correlación; detalle solo en logs internos. Referencia: OWASP Top 10:2025 A10

Servicio de Autenticación (Proceso)

Descripción: Proveedor de identidad (OAuth 2.0 / OIDC): valida credenciales, OTP y emite tokens.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
	T16 – Evasión o fuerza bruta del OTP	Spoofing	Alta	Abierto		El atacante reutiliza un OTP, lo adivina por fuerza bruta o salta el paso de verificación.	OTP de un solo uso, ligado a la operación, con expiración de 2–5 min y máximo 3–5 intentos; preferir push firmado o FIDO2. Referencia: NIST SP 800-63B
	T17 – Recuperación de acceso débil	Elevation of privilege	Alta	Abierto		El proceso de 'olvidé mi PIN' o cambio de teléfono permite tomar la cuenta con datos fáciles de obtener.	Reverificación fuerte (documento + prueba de vida facial); periodo de enfriamiento para transferencias tras la recuperación; notificación por canales previos. Referencia: NIST SP 800-63A
	T18 – Enumeración de usuarios	Information disclosure	Baja	Abierto		Respuestas o tiempos distintos para usuarios existentes y no existentes permiten armar listas de clientes.	Respuestas y tiempos uniformes; rate limiting en login y recuperación. Referencia: OWASP ASVS V2

Core Bancario (Proceso)

Descripción: Sistema central: cuentas, saldos, débitos, créditos y transferencias.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
	T23 – Manipulación del monto o cuenta destino	Tampering	Alta	Abierto		El atacante altera el monto o la cuenta destino entre la confirmación del cliente y la ejecución.	Validación en el servidor; firma de la transacción que incluye monto y destino (lo que ves es lo que firmas); OTP/confirmación ligada a esos datos. Referencia: PSD2 RTS Art. 5 (dynamic linking)
	T24 – Transacciones sin logs firmados	Repudiation	Alta	Abierto		Sin registros íntegros no se puede probar quién hizo qué ni cuándo; el fraude interno o externo queda sin trazabilidad.	Logs de auditoría append-only con hash encadenado o firma; sello de tiempo sincronizado (NTP); ID de correlación de extremo a extremo; envío a SIEM. Referencia: OWASP Top 10:2025 A09; PCI DSS 10
	T25 – Cuenta de servicio del API con privilegios excesivos	Elevation of privilege	Alta	Abierto		Si se compromete el API Gateway, su cuenta en el Core permite operaciones administrativas (ajustes de saldo, altas de cuentas).	Mínimo privilegio por operación; mTLS entre servicios; segmentación y enfoque zero trust; operaciones administrativas solo desde red de gestión. Referencia: NIST SP 800-207
	T26 – Saturación del Core Bancario	Denial of service	Media	Abierto		Picos de tráfico o consultas costosas agotan los recursos del core y afectan a todos los canales.	Colas y límites por cliente; circuit breakers y timeouts; caché de consultas de saldo; plan de capacidad. Referencia: OWASP API Security Top 10 (API4)

Almacén seguro del dispositivo (Dispositivo de almacenamiento)

Descripción: Keystore (Android) / Keychain (iOS): tokens de sesión y claves del dispositivo.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
	T07 – Extracción de tokens del almacenamiento local	Information disclosure	Alta	Abierto		Tokens guardados en SharedPreferences, archivos o copias de seguridad son copiados por malware o por acceso físico.	Guardar tokens solo en Keystore/Keychain con clave respaldada por hardware; excluir de backups; access token de vida corta y refresh token ligado al dispositivo (DPoP / mTLS). Referencia: MASVS-STORAGE; RFC 9449 (DPoP)
	T08 – Alteración de datos locales de configuración	Tampering	Media	Abierto		Se modifican valores locales (límites, banderas de funcionalidades, cuentas favoritas) para inducir errores o fraude.	No confiar en datos locales para decisiones de seguridad; firmar la configuración remota y validarla en el servidor. Referencia: MASVS-CODE

BD Clientes y Credenciales (Dispositivo de almacenamiento)

Descripción: Datos personales, hashes de PIN/contraseña, dispositivos vinculados.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
	T21 – Filtración de la base de clientes y credenciales	Information disclosure	Alta	Abierto		Una inyección SQL o un acceso indebido expone datos personales y hashes de PIN/contraseña.	Consultas parametrizadas; hash Argon2id/bcrypt con sal; cifrado en reposo (TDE); cuentas de servicio con mínimo privilegio; segmentación de red. Referencia: OWASP Top 10:2025 A05; PCI DSS 8.3
	T22 – Cambio indebido del teléfono o correo del cliente	Tampering	Media	Abierto		Un insider o un atacante interno cambia el número de contacto para recibir los OTP del cliente.	Control dual (4 ojos) para cambios de datos de contacto; notificación al canal anterior; auditoría y gestión de accesos privilegiados (PAM). Referencia: ISO/IEC 27001 A.8.2

BD Cuentas y Transacciones (Dispositivo de almacenamiento)

Descripción: Saldos, movimientos e historial de transferencias.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
	T27 – Doble gasto por condición de carrera	Tampering	Alta	Abierto		Dos transferencias simultáneas debitan el mismo saldo o se alteran registros de movimientos.	Transacciones ACID con bloqueo; claves de idempotencia; conciliación diaria automática. Referencia: CWE-362
	T28 – Exposición de datos financieros en respaldos o ambientes de prueba	Information disclosure	Media	Abierto		Copias de seguridad sin cifrar o datos reales en desarrollo exponen saldos y movimientos.	Cifrado de respaldos; enmascaramiento de datos en ambientes no productivos; control de acceso a respaldos. Referencia: PCI DSS 3.5

Logs de auditoría (Dispositivo de almacenamiento)

Descripción: Registro de eventos de seguridad y transacciones (SIEM).

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
	T29 – Borrado o alteración de logs	Tampering	Alta	Abierto		Un atacante o insider elimina registros para ocultar un fraude.	Almacenamiento WORM / inmutable; envío en tiempo real al SIEM; separación de funciones entre operadores y auditores. Referencia: PCI DSS 10.3
	T30 – Datos sensibles registrados en logs	Information disclosure	Media	Abierto		Tokens, PIN o números completos de tarjeta quedan escritos en texto plano en los logs.	Enmascaramiento y lista de campos prohibidos; revisión automática de logs; acceso restringido. Referencia: OWASP Logging Cheat Sheet
	T31 – Pérdida de eventos por saturación de logs	Denial of service	Baja	Abierto		Un atacante genera eventos masivos para llenar el almacenamiento y perder registros posteriores.	Rotación y cuotas; alertas de capacidad; agregación y muestreo de eventos no críticos. Referencia: CWE-400

Credenciales / PIN / biometría (Flujo de datos)

Descripción: F01: Credenciales / PIN / biometría

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
	T35 – Captura del PIN mediante overlay o keylogger	Information disclosure	Media	Abierto		Malware con permisos de accesibilidad dibuja una pantalla falsa sobre la app o registra las pulsaciones y obtiene el PIN del cliente.	Teclado propio de la app para el PIN; detección de overlays y de servicios de accesibilidad sospechosos; preferir biometría ligada al Keystore. Referencia: MASVS-PLATFORM; MASVS-AUTH

Guardar tokens (Flujo de datos)

Descripción: F02: Guardar tokens

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
	T36 – Tokens expuestos antes de llegar al almacén seguro	Information disclosure	Baja	Abierto		El token recibido queda en memoria, en logs de depuración o en variables compartidas antes de guardarse en el Keystore.	Pasar el token directamente al Keystore/Keychain; borrar copias en memoria; compilar sin logs de depuración en producción. Referencia: MASVS-STORAGE

Login y operaciones (HTTPS + token) (Flujo de datos)

Descripción: F03: Login y operaciones (HTTPS + token)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
	T09 – Intercepción (MITM) de credenciales y tokens	Information disclosure	Alta	Abierto		En una Wi-Fi pública o con una CA maliciosa instalada, el atacante intercepta el tráfico entre la app y la API.	TLS 1.2+/1.3 obligatorio; certificate pinning; no confiar en CA instaladas por el usuario (Network Security Config / ATS). Referencia: MASVS-NETWORK
	T10 – Repetición (replay) o alteración de solicitudes	Tampering	Media	Abierto		Una solicitud de transferencia capturada se reenvía varias veces o se modifica en tránsito.	Firma de la solicitud con nonce y marca de tiempo; claves de idempotencia; rechazo de solicitudes duplicadas o expiradas. Referencia: OWASP ASVS V13

Tokens / saldo / comprobante (Flujo de datos)

Descripción: F04: Tokens / saldo / comprobante

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
	T11 – Tokens o datos expuestos en respuestas y URLs	Information disclosure	Media	Abierto		Tokens en parámetros de URL o respuestas con más datos de los necesarios quedan en logs de proxies o del dispositivo.	Tokens solo en encabezados/cuerpo; respuestas con el mínimo de datos; cabeceras Cache-Control: no-store. Referencia: OWASP API Security Top 10 (API3)

Validar credenciales y OTP (Flujo de datos)

Descripción: F05: Validar credenciales y OTP

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
	T37 – Saturación del servicio de autenticación	Denial of service	Media	Abierto		Picos de intentos de login reenviados por el API Gateway agotan el servicio de autenticación y bloquean el acceso de todos los clientes.	Rate limiting antes del servicio de autenticación; colas y circuit breakers entre el gateway y el IdP; autoescalado. Referencia: OWASP API Security Top 10 (API4)

Consultar hash y dispositivo (Flujo de datos)

Descripción: F06: Consultar hash y dispositivo

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
	T38 – Inyección SQL en la consulta de credenciales	Tampering	Alta	Abierto		Un parámetro de login no validado altera la consulta a la BD de clientes y permite iniciar sesión sin conocer el PIN.	Consultas parametrizadas u ORM; validación de entrada; cuenta de BD de solo lectura para el servicio de autenticación. Referencia: OWASP Top 10:2025 A05; CWE-89

Solicitud de OTP (Flujo de datos)

Descripción: F07: Solicitud de OTP

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
	T39 – Exposición de datos del cliente al proveedor de SMS	Information disclosure	Media	Abierto		El número de teléfono, el OTP y el texto del mensaje quedan almacenados en los sistemas y logs de un tercero.	Enviar solo los datos mínimos; OTP de un solo uso y vida corta; acuerdo de tratamiento de datos y evaluación de seguridad del proveedor. Referencia: ISO/IEC 27001 A.5.19

OTP por SMS / Push (Flujo de datos)

Descripción: F08: OTP por SMS / Push

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
	T19 – Intercepción del OTP enviado por SMS	Information disclosure	Alta	Abierto		El SMS puede ser leído por malware, interceptado vía SS7 o desviado por SIM swapping.	Reemplazar SMS por notificación push autenticada o autenticador en la app; si se usa SMS, incluir monto y destino en el mensaje y no permitir su lectura por otras apps. Referencia: NIST SP 800-63B §5.1.3.3

Operación autorizada (saldo / transferencia) (Flujo de datos)

Descripción: F09: Operación autorizada (saldo / transferencia)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
	T32 – Tráfico interno sin cifrar	Information disclosure	Media	Abierto		Dentro de la red del banco el tráfico entre API y Core puede ser capturado por un atacante que ya está dentro.	mTLS en todo tráfico interno; segmentación de red. Referencia: NIST SP 800-207

Leer / escribir movimientos (Flujo de datos)

Descripción: F10: Leer / escribir movimientos

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
	T40 – Bloqueos en la base de datos por transacciones concurrentes	Denial of service	Baja	Abierto		Transacciones largas o bloqueos mutuos (deadlocks) en la BD de cuentas dejan sin servicio las transferencias y las consultas de saldo.	Transacciones cortas con orden de bloqueo consistente; timeouts; réplicas de lectura para consultas de saldo. Referencia: CWE-833

Transferencia interbancaria (Flujo de datos)

Descripción: F11: Transferencia interbancaria

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
	T33 – Mensajes interbancarios falsificados	Spoofing	Media	Abierto		Se inyectan o alteran órdenes de transferencia hacia la red interbancaria.	Canal dedicado con mTLS/VPN; firma de mensajes según el estándar de la cámara (ISO 20022); conciliación. Referencia: ISO 20022; SWIFT CSP

Eventos de auditoría (Flujo de datos)

Descripción: F12: Eventos de auditoría

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
	T41 – Eventos de auditoría alterados o suprimidos en tránsito	Tampering	Media	Abierto		Un atacante en la red interna modifica o descarta eventos de auditoría antes de que lleguen al almacén de logs.	TLS en el envío de eventos; firma de cada evento en origen; número de secuencia para detectar eventos faltantes. Referencia: OWASP Logging Cheat Sheet; PCI DSS 10.3